

Scenario 2 output 1 chatgpt

Threat 1 — Unauthorized File Access

- **Threat ID:** S2-T01
- **Threat name:** Unauthorized File Retrieval
- **Category:** Authorization / STRIDE — Elevation of Privilege
- **Affected component/data flow:** EE1 → P1 → P2 → DS1
- **Attack description:** An attacker submits a retrieval request for a file they do not own or have permission to access. The attack may involve manipulating the filename, file identifier, or retrieval parameters so that P2 retrieves another user's file.
- **Impact:** Exposure of confidential documents and potential disclosure of sensitive personal or organizational information.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** P2 must perform authorization checks for every retrieval request using DS2 as the authoritative permission source. Authorization must be based on the authenticated user identity and the specific file, not merely on a user-supplied filename or identifier. Deny access by default.
- **OWASP mapping:** OWASP LLM Top 10 — LLM06 Excessive Agency; OWASP LLM02 Sensitive Information Disclosure; OWASP LLM01 Prompt Injection where AI-assisted retrieval requests influence downstream processing.

Threat 2 — Broken Object-Level Authorization

- **Threat ID:** S2-T02
- **Threat name:** IDOR / Broken File-Level Authorization
- **Category:** Authorization / STRIDE — Elevation of Privilege
- **Affected component/data flow:** EE1 → P1 → P2 → DS2/DS1
- **Attack description:** The attacker modifies a file identifier, filename, or other object reference to access a different file. If P2 verifies that the request is structurally valid but fails to verify ownership or permission for that exact file, unauthorized access occurs.
- **Impact:** Cross-user file disclosure.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** Enforce object-level authorization in P2 for every file operation. Never rely on identifiers supplied by EE1 as evidence of authorization. Test authorization using horizontal privilege-escalation cases.
- **OWASP mapping:** OWASP LLM06 Excessive Agency; OWASP LLM02 Sensitive Information Disclosure.

Threat 3 — Authorization Database Manipulation

- **Threat ID:** S2-T03

- **Threat name:** Manipulation of Authoritative Permissions
- **Category:** Authorization / STRIDE — Tampering
- **Affected component/data flow:** P2 ↔ DS2
- **Attack description:** If an attacker can influence the permission information used by P2, they could cause the service to believe that the attacker has access to files they should not access.
- **Impact:** Unauthorized access to potentially all files associated with manipulated permissions.
- **Severity:** Critical
- **Likelihood:** Low
- **Mitigation:** P2 must treat DS2 as the authoritative authorization source and ensure permission data cannot be modified through untrusted user inputs. Authorization data should only be changed through explicitly authorized operations.
- **OWASP mapping:** OWASP LLM06 Excessive Agency; OWASP LLM02 Sensitive Information Disclosure.

Threat 4 — Authorization Bypass Through the AI Assistant

- **Threat ID:** S2-T04
- **Threat name:** AI-Based Authorization Bypass
- **Category:** Authorization / LLM-specific
- **Affected component/data flow:** EE1 → P1 → P3 → P4 → External LLM Provider
- **Attack description:** A user attempts to convince P3 or the LLM to retrieve or reveal a file that the user is not authorized to access. The attacker may phrase requests such as asking the assistant to "ignore permissions," retrieve another user's document, or provide information from unavailable documents.
- **Impact:** Unauthorized disclosure if AI-generated behavior is incorrectly treated as an authorization decision.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** P3 and P4 must never determine authorization. Only P2 may authorize access. The AI pipeline must receive document context only after P2 has approved access. AI-generated responses must never trigger direct file retrieval.
- **OWASP mapping:** OWASP LLM06 Excessive Agency; OWASP LLM01 Prompt Injection; OWASP LLM02 Sensitive Information Disclosure.

Threat 5 — Prompt Injection Through Uploaded Documents

- **Threat ID:** S2-T05
- **Threat name:** Indirect Prompt Injection
- **Category:** LLM-specific / STRIDE — Elevation of Privilege
- **Affected component/data flow:** Uploaded file → DS1 → P2 → P3 → P4 → External LLM Provider
- **Attack description:** A malicious document contains instructions designed to manipulate the LLM, for example instructions telling the AI to ignore previous instructions, disclose hidden information, or alter its response behavior. When the document is later supplied as authorized context, the malicious content becomes part of the LLM input.
- **Impact:** Manipulated AI responses, sensitive-context disclosure, misleading document analysis, or attempts to influence downstream processing.
- **Severity:** High

- **Likelihood:** High
- **Mitigation:** Treat all document content as untrusted data rather than instructions. P4 should clearly separate system instructions from document content. Apply prompt-injection-resistant prompt construction, content delimiting, output validation, and least-privilege design. Never allow LLM instructions contained in documents to authorize additional file access.
- **OWASP mapping:** OWASP LLM01 Prompt Injection.

Threat 6 — Malicious Document Content

- **Threat ID:** S2-T06
- **Threat name:** Malicious Uploaded File
- **Category:** File Security / STRIDE — Tampering
- **Affected component/data flow:** EE1 → P1 → P2 → DS1
- **Attack description:** An attacker uploads a malicious or deliberately crafted document containing harmful content, misleading instructions, malformed structures, or payloads intended to affect downstream document processing.
- **Impact:** Integrity compromise, unsafe AI responses, denial of service, or exploitation of weaknesses in file-processing functionality.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Validate uploaded files, enforce permitted file types and size limits, treat document contents as untrusted, and safely process documents before they become AI context. File validation should occur before storage and subsequent processing.
- **OWASP mapping:** OWASP LLM01 Prompt Injection; OWASP LLM10 Unbounded Consumption where malicious files cause excessive processing.

Threat 7 — Sensitive Document Exposure to the LLM

- **Threat ID:** S2-T07
- **Threat name:** Unauthorized Context Disclosure
- **Category:** Data Leakage / LLM-specific
- **Affected component/data flow:** P2 → P3 → P4 → EE2
- **Attack description:** P2 may authorize access to a document, but excessive or incorrectly selected context could expose more document information to the external LLM than is necessary to answer the user's question.
- **Impact:** Sensitive document information leaves application control and is disclosed to EE2.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Apply data minimization when constructing AI context. P3 should provide only the information necessary for the user's question. P4 must send only sanitized prompts and authorization-approved context. Do not include unrelated files, permission data, or private metadata.
- **OWASP mapping:** OWASP LLM02 Sensitive Information Disclosure; OWASP LLM06 Excessive Agency.

Threat 8 — Cross-Document Context Leakage

- **Threat ID:** S2-T08

- **Threat name:** Context Mixing Between Users or Documents
- **Category:** Data Leakage / LLM-specific
- **Affected component/data flow:** DS1 → P3 → P4 → External LLM Provider
- **Attack description:** Context belonging to one document or user could accidentally be included when answering a question about another document. This could occur through incorrect context selection or insufficient isolation of authorization-approved context.
- **Impact:** Disclosure of another user's document information.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** Bind every AI context request to the requesting user and specifically authorized file. P2 should approve the exact document context being supplied. P3 must not combine contexts unless each included document is independently authorized.
- **OWASP mapping:** OWASP LLM02 Sensitive Information Disclosure; OWASP LLM06 Excessive Agency.

Threat 9 — Private Metadata Leakage

- **Threat ID:** S2-T09
- **Threat name:** Metadata Disclosure to External LLM
- **Category:** Data Leakage
- **Affected component/data flow:** DS1 → P3/P4 → EE2
- **Attack description:** File metadata that is not necessary for answering a question could accidentally be incorporated into the LLM context or prompt.
- **Impact:** Exposure of private metadata such as ownership information or other sensitive file attributes.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Explicitly filter metadata before P4 creates the external LLM request. Send only the minimum document content required. Never send DS2 contents to EE2.
- **OWASP mapping:** OWASP LLM02 Sensitive Information Disclosure.

Threat 10 — Permission Database Exposure

- **Threat ID:** S2-T10
- **Threat name:** Authorization Data Disclosure
- **Category:** Confidentiality / STRIDE — Information Disclosure
- **Affected component/data flow:** DS2 → P2
- **Attack description:** An attacker attempts to obtain user identities, file ownership information, or permission records. Such information could also reveal relationships between users and confidential files.
- **Impact:** Privacy breach and potential preparation for further authorization attacks.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Keep DS2 strictly within the authorization function of P2. Never provide permission database contents to P3, P4, EE1, or EE2. Return only the minimum authorization result necessary.
- **OWASP mapping:** OWASP LLM02 Sensitive Information Disclosure.

Threat 11 — Prompt Injection Through User Questions

- **Threat ID:** S2-T11
- **Threat name:** Direct Prompt Injection
- **Category:** LLM-specific
- **Affected component/data flow:** EE1 → P1 → P3 → P4 → EE2
- **Attack description:** A malicious user constructs questions specifically designed to override the intended instructions given to the LLM, manipulate its behavior, or persuade it to reveal information outside the intended document context.
- **Impact:** Manipulated responses, information disclosure, or unsafe behavior.
- **Severity:** High
- **Likelihood:** High
- **Mitigation:** Treat user questions as untrusted input. Use strong separation between instructions and user content, constrain the context supplied to the LLM, and validate generated responses before displaying them.
- **OWASP mapping:** OWASP LLM01 Prompt Injection.

Threat 12 — LLM Hallucination and Incorrect Document Answers

- **Threat ID:** S2-T12
- **Threat name:** Unreliable AI-Generated Information
- **Category:** LLM-specific / Integrity
- **Affected component/data flow:** P4 → P3 → P1 → EE1
- **Attack description:** The external LLM may generate information that is not supported by the authorization-approved document context.
- **Impact:** Users may receive false or misleading interpretations of documents.
- **Severity:** Medium
- **Likelihood:** High
- **Mitigation:** Restrict responses to supplied context, instruct the model to identify insufficient information, validate outputs where possible, and clearly treat generated answers as untrusted.
- **OWASP mapping:** OWASP LLM09 Misinformation.

Threat 13 — Insecure LLM Output Handling

- **Threat ID:** S2-T13
- **Threat name:** Unsafe AI Output
- **Category:** LLM-specific / STRIDE — Tampering
- **Affected component/data flow:** EE2 → P4 → P3 → P1
- **Attack description:** The LLM output is explicitly untrusted. If P1 or P3 treats generated content as trusted instructions, structured data, or executable content, malicious or manipulated output could affect subsequent processing.
- **Impact:** Integrity compromise, misleading information, or potentially unsafe frontend behavior.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Treat all LLM output as untrusted data. Validate and constrain output before use. Do not allow generated output to become an authorization instruction or direct file-operation command.
- **OWASP mapping:** OWASP LLM05 Improper Output Handling.

Threat 14 — Excessive AI Permissions

- **Threat ID:** S2-T14
- **Threat name:** Excessive AI Privilege
- **Category:** LLM-specific / Authorization
- **Affected component/data flow:** P3/P4 ↔ P2/DS1
- **Attack description:** The AI assistant could be given capabilities beyond its stated role, such as direct access to DS1 or the ability to initiate unauthorized file operations.
- **Impact:** A successful prompt injection or compromised AI process could become a path to unauthorized file access.
- **Severity:** Critical
- **Likelihood:** Low under the stated architecture
- **Mitigation:** Maintain the stated architectural restriction: P3 cannot access DS1 directly and cannot make authorization decisions. P2 must remain the sole authorization enforcement point.
- **OWASP mapping:** OWASP LLM06 Excessive Agency.

Threat 15 — LLM Provider Data Exposure

- **Threat ID:** S2-T15
- **Threat name:** External Provider Confidentiality Risk
- **Category:** External Entity / Data Leakage
- **Affected component/data flow:** P4 → EE2
- **Attack description:** Approved document context and sanitized prompts leave the application's trust boundary and are sent to EE2. Risks associated with the external provider may include unintended retention, processing, or exposure of the transmitted information.
- **Impact:** Confidential document information may be exposed outside application control.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Minimize the context sent to EE2, sanitize prompts, exclude private metadata and permission information, and transmit only information explicitly required for the AI response. External-provider handling must be treated as an explicit trust-boundary risk.
- **OWASP mapping:** OWASP LLM02 Sensitive Information Disclosure; OWASP LLM03 Supply Chain.

Threat 16 — Malicious Content Designed to Manipulate AI Interpretation

- **Threat ID:** S2-T16
- **Threat name:** Document-Based Semantic Manipulation
- **Category:** File Security / LLM-specific
- **Affected component/data flow:** EE1 → DS1 → P3 → P4
- **Attack description:** A user uploads a document containing deceptive text intended to make the AI misinterpret the document or provide a misleading answer to later users.
- **Impact:** Users can receive manipulated document interpretations and make decisions based on false information.
- **Severity:** Medium

- **Likelihood:** High
- **Mitigation:** Treat document content as untrusted, distinguish document statements from system instructions, and avoid allowing document content to alter the assistant's operating rules.
- **OWASP mapping:** OWASP LLM01 Prompt Injection; OWASP LLM09 Misinformation.

Threat 17 — File Overwrite or Destructive Storage Operation

- **Threat ID:** S2-T17
- **Threat name:** Unauthorized File Modification
- **Category:** File Security / STRIDE — Tampering
- **Affected component/data flow:** EE1 → P1 → P2 → DS1
- **Attack description:** An attacker attempts to overwrite, replace, or otherwise modify a file belonging to another user by manipulating upload or storage parameters.
- **Impact:** Loss of file integrity and potential destruction or replacement of legitimate documents.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** P2 must authorize storage operations against the specific target file and user identity. Prevent users from modifying files they do not own or have modification rights for.
- **OWASP mapping:** OWASP LLM06 Excessive Agency.

Threat 18 — File Identifier or Filename Manipulation

- **Threat ID:** S2-T18
- **Threat name:** Malicious Filename / Path Manipulation
- **Category:** File Security / STRIDE — Tampering
- **Affected component/data flow:** EE1 → P1 → P2 → DS1
- **Attack description:** An attacker supplies specially crafted filenames or file identifiers to manipulate how P2 identifies or stores files.
- **Impact:** Unauthorized access, file overwriting, incorrect file association, or storage integrity problems.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Treat filenames and identifiers as untrusted. Validate and normalize them before use, use internally controlled file identifiers, and ensure authorization is performed against the canonical file object.
- **OWASP mapping:** OWASP LLM06 Excessive Agency; OWASP LLM02 Sensitive Information Disclosure where manipulation results in unauthorized retrieval.

Threat 19 — Unbounded File or Query Processing

- **Threat ID:** S2-T19
- **Threat name:** Resource Exhaustion
- **Category:** Availability / STRIDE — Denial of Service
- **Affected component/data flow:** EE1 → P1 → P2/P3/P4 → DS1/EE2
- **Attack description:** An attacker submits extremely large files, oversized queries, or repeated AI requests to consume file-processing, AI-processing, or external LLM resources.
- **Impact:** Service degradation or denial of service.

- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Enforce file-size limits, request limits, context-size limits, and rate limits. Reject excessively large or malformed inputs before expensive AI processing.
- **OWASP mapping:** OWASP LLM10 Unbounded Consumption.

Threat 20 — AI-Assisted Denial of Service

- **Threat ID:** S2-T20
- **Threat name:** Excessive LLM Consumption
- **Category:** LLM-specific / Availability
- **Affected component/data flow:** EE1 → P3 → P4 → EE2
- **Attack description:** A malicious user repeatedly submits computationally expensive document questions or requests that cause P4 to make excessive external LLM requests.
- **Impact:** Resource exhaustion, increased external service consumption, degraded availability.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Apply request throttling, input limits, context-size restrictions, and controlled usage quotas before invoking EE2.
- **OWASP mapping:** OWASP LLM10 Unbounded Consumption.

Threat 21 — Sensitive Information Inferred From AI Responses

- **Threat ID:** S2-T21
- **Threat name:** Inference-Based Data Leakage
- **Category:** Data Leakage / LLM-specific
- **Affected component/data flow:** P4 → P3 → P1 → EE1
- **Attack description:** A user asks a series of questions designed to infer sensitive information from an authorized document or from the way the assistant responds.
- **Impact:** Information may be disclosed even when the exact underlying document content is not directly returned.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Ensure the assistant answers only within the authorization-approved context and does not expose unrelated document information. Apply context minimization and avoid revealing hidden system or authorization information.
- **OWASP mapping:** OWASP LLM02 Sensitive Information Disclosure; OWASP LLM01 Prompt Injection.

Threat 22 — System Prompt or Internal Instruction Extraction

- **Threat ID:** S2-T22
- **Threat name:** Prompt Leakage
- **Category:** LLM-specific / Information Disclosure
- **Affected component/data flow:** EE1 → P3 → P4 → EE2 → P1

- **Attack description:** A user attempts to persuade the LLM to reveal internal instructions, prompt structure, or other information included in the LLM interaction.
- **Impact:** Disclosure of internal application logic or prompt design that can help attackers construct further attacks.
- **Severity:** Medium
- **Likelihood:** High
- **Mitigation:** Do not place sensitive secrets in prompts. Treat requests for internal instructions as untrusted. Maintain strict separation between internal instructions and user/document content.
- **OWASP mapping:** OWASP LLM07 System Prompt Leakage.

Threat 23 — LLM Supply-Chain Risk

- **Threat ID:** S2-T23
- **Threat name:** External LLM Dependency Risk
- **Category:** LLM-specific / Supply Chain
- **Affected component/data flow:** P4 ↔ EE2
- **Attack description:** The application depends on an external LLM provider outside its direct control. Changes or weaknesses in the provider's model, service behavior, or processing environment could affect confidentiality, integrity, or availability.
- **Impact:** Unexpected model behavior, data exposure, service disruption, or security regression.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Minimize data sent to EE2, treat all returned content as untrusted, maintain strict boundaries around P4, and avoid allowing provider behavior to bypass P2 authorization.
- **OWASP mapping:** OWASP LLM03 Supply Chain.

Threat 24 — Authorization Confusion Between P2 and AI Components

- **Threat ID:** S2-T24
- **Threat name:** Authorization Responsibility Drift
- **Category:** Authorization / Architecture
- **Affected component/data flow:** P2 ↔ P3 ↔ P4
- **Attack description:** A design or implementation error could cause P3 or P4 to be treated as an authorization component even though the architecture explicitly states that P2 is the only authorization enforcement point.
- **Impact:** Inconsistent authorization decisions and potential access-control bypass.
- **Severity:** Critical
- **Likelihood:** Low
- **Mitigation:** Enforce a hard architectural boundary: P2 authorizes every file operation; P3 only handles approved context; P4 only performs LLM integration. AI-generated output must never be treated as an authorization decision.
- **OWASP mapping:** OWASP LLM06 Excessive Agency.

Threat 25 — Tampering With AI Context

- **Threat ID:** S2-T25
- **Threat name:** Context Integrity Manipulation
- **Category:** Integrity / LLM-specific
- **Affected component/data flow:** DS1 → P3 → P4 → EE2
- **Attack description:** Malicious document content or manipulated context construction could alter the information presented to the LLM, causing it to produce an incorrect or attacker-controlled interpretation.
- **Impact:** Incorrect AI responses, misleading document analysis, and potential information disclosure.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Preserve the integrity of authorization-approved context, clearly delimit document content, treat embedded instructions as data, and ensure P3 cannot substitute unauthorized documents into the context.
- **OWASP mapping:** OWASP LLM01 Prompt Injection; OWASP LLM09 Misinformation.

Threat 26 — Information Disclosure Through Error Responses

- **Threat ID:** S2-T26
- **Threat name:** Authorization and File Error Leakage
- **Category:** STRIDE — Information Disclosure
- **Affected component/data flow:** P2 → P1 → EE1
- **Attack description:** Detailed error responses could reveal whether a particular file exists, who owns it, or what permissions are associated with it, even when the user is not authorized to access the file.
- **Impact:** File existence and metadata disclosure that can assist further attacks.
- **Severity:** Medium
- **Likelihood:** Medium
- **Mitigation:** Use carefully controlled error messages. Do not expose permission records, ownership information, internal file identifiers, or unnecessary storage details to unauthorized users.
- **OWASP mapping:** OWASP LLM02 Sensitive Information Disclosure.

Threat 27 — Spoofed User Identity

- **Threat ID:** S2-T27
- **Threat name:** Identity Spoofing
- **Category:** STRIDE — Spoofing
- **Affected component/data flow:** EE1 → P1 → P2 → DS2
- **Attack description:** An attacker attempts to cause P2 to evaluate permissions using another user's identity. Because DS2 contains user identity and permissions, incorrect identity association could result in unauthorized file access.
- **Impact:** Complete bypass of intended file authorization if the attacker is evaluated as another user.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** P2 must use a trustworthy authenticated user identity when evaluating DS2 permissions and must not accept user-supplied identity information as proof of identity.

- **OWASP mapping:** OWASP LLM06 Excessive Agency; OWASP LLM02 Sensitive Information Disclosure.

Threat 28 — Repudiation of File Operations

- **Threat ID:** S2-T28
- **Threat name:** Lack of Reliable Operation Attribution
- **Category:** STRIDE — Repudiation
- **Affected component/data flow:** EE1 → P1 → P2 → DS1
- **Attack description:** If file operations cannot be reliably associated with the requesting user, it may be difficult to determine who uploaded or retrieved a document after a security incident.
- **Impact:** Reduced incident investigation capability and difficulty establishing accountability.
- **Severity:** Medium
- **Likelihood:** Medium
- **Mitigation:** Maintain reliable attribution of file operations to the authenticated user within the existing P1/P2 flow. Security-relevant operations should be traceable to the identity used for authorization.
- **OWASP mapping:** No direct OWASP LLM Top 10 category; primarily STRIDE Repudiation.

Threat 29 — File Availability Attack

- **Threat ID:** S2-T29
- **Threat name:** Storage Exhaustion
- **Category:** File Security / STRIDE — Denial of Service
- **Affected component/data flow:** EE1 → P1 → P2 → DS1
- **Attack description:** An attacker uploads excessive numbers or sizes of files, consuming the available storage repository.
- **Impact:** Legitimate users may be unable to upload or retrieve files.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Enforce upload size and usage limits through P2, reject excessive uploads, and restrict storage operations according to the user's permitted capabilities.
- **OWASP mapping:** OWASP LLM10 Unbounded Consumption.

Threat 30 — Malicious File Used as an AI Attack Vector

- **Threat ID:** S2-T30
- **Threat name:** File-to-LLM Attack Chain
- **Category:** LLM-specific / File Security
- **Affected component/data flow:** EE1 → P1 → P2 → DS1 → P3 → P4 → EE2
- **Attack description:** An attacker uploads a malicious document containing prompt-injection instructions. Later, an authorized user asks the AI assistant about that document. The malicious document content is then passed as authorization-approved context to the LLM, where it attempts to manipulate model behavior.
- **Impact:** This creates a complete attack chain from untrusted file upload to LLM manipulation and potentially sensitive-information disclosure.
- **Severity:** Critical

- **Likelihood:** High
- **Mitigation:** Treat every uploaded document as untrusted even after P2 authorizes access. Separate document content from instructions, sanitize and delimit context, minimize the supplied context, validate LLM output, and ensure no LLM output can bypass P2.
- **OWASP mapping:** OWASP LLM01 Prompt Injection; OWASP LLM02 Sensitive Information Disclosure; OWASP LLM06 Excessive Agency; OWASP LLM09 Misinformation.